

SDK / стек

Параметр	Значение
Название приложения	Tigrano Maze Zip Cat
Android Gradle Plugin	8.11.1
minSdk	24
targetSdk	36
Kotlin	да, 2.2.20
Web View	да
Custom Tabs	нет
Рекламные сети	нет
Аналитика	Firebase Cloud Messaging, Firebase Installations, Firebase Realtime Database
Permissions	android.permission.INTERNET, android.permission.ACCESS_NETWORK_STATE, android.permission.POST_NOTIFICATIONS, android.permission.WAKE_LOCK, com.google.android.c2dm.permission.RECEIVE, com.devanos.nilufar.usmonova.DYNAMIC_RECEIVER_NOT_EXPORTED_PERMISSION
Libraries	Flutter (io.flutter.embedding.v2), Kotlin 2.2.20, Jetpack Compose, AndroidX AppCompat, Activity, Core, Lifecycle, DataStore Preferences, Emoji2, ProfileInstaller, Startup, Window; Retrofit2, OkHttp3, Moshi (Square); Firebase Database, Firebase Messaging, Firebase Installations, Firebase Common; Play Services (base/basement/tasks/cloud-messaging); kotlinx-coroutines
Подозрительные домены	ranoaudio-mix.quest, date123456.com, ranoaudio-mix-default-rtdb.europe-west1.firebaseio.com
SharedPreferences	DataStore Preferences (p7_prefs): install_id, idfv, p7_pd (флаг принятия policy), fcm_token, pending_click_id (click_id из deep link до POST на сервер)
Есть ли клоака	да
Подозрительные слова	click_id, pending_click_id, keitaro_off, open_policy, block_token, antiFraudRepository, Gate, S0, MainStub, hApi, hFp, save_link, startup, Decision, RTDB, persist

Проверка домена: ranoaudio-mix-default-rtdb.europe-west1.firebaseio.com

Параметр / движок	Значение / вердикт
Домен	ranoaudio-mix-default-rtdb.europe-west1.firebaseio.com
VirusTotal URL	https://www.virustotal.com/gui/domain/ranoaudio-mix-default-rtdb.firebaseio.com
Детекции	0/91 (malicious=0, suspicious=0)
Security vendors' analysis	ниже построчно, как на VirusTotal
0xSI_f33d	Unrated
Abusix	Unrated
Acronis	Unrated
ADMINUSLabs	Unrated
AILabs (MONITORAPP)	Unrated
AlienVault	Unrated
alphaMountain.ai	Unrated
AlphaSOC	Unrated
Antiy-AVL	Unrated
ArcSight Threat Intelligence	Unrated
AutoShun	Unrated
Axur	Unrated
Bfore.Ai PreCrime	Unrated
BitDefender	Unrated
Bkav	Unrated
Blueliv	Unrated
Certego	Unrated
ChainPatrol	Unrated
Chong Lua Dao	Unrated
CINS Army	Unrated
Cluster25	Unrated
CMC Threat Intelligence	Unrated
CRDF	Unrated

Параметр / движок	Значение / вердикт
Criminal IP	Unrated
CSIS Security Group	Unrated
CTX AI	Unrated
Cyan	Unrated
Cyble	Unrated
CyRadar	Unrated
desenmascara.me	Unrated
DNS8	Unrated
Dr.Web	Unrated
EmergingThreats	Unrated
Emsisoft	Unrated
Ermes	Unrated
ESET	Unrated
ESTsecurity	Unrated
Forcepoint ThreatSeeker	Unrated
Fortinet	Unrated
Fortra	Unrated
G-Data	Unrated
GCP Abuse Intelligence	Unrated
Google Safe Browsing	Unrated
GreenSnow	Unrated
GreyNoise	Unrated
Gridinsoft	Unrated
Guardpot	Unrated
Heimdal Security	Unrated
Hunt.io Intelligence	Unrated
IPsum	Unrated
Juniper Networks	Unrated
Kaspersky	Unrated
LevelBlue	Unrated
Lionic	Unrated
Lumu	Unrated
Malwared	Unrated
MalwarePatrol	Unrated
MalwareURL	Unrated
Mimecast	Unrated
Netcraft	Unrated
OpenPhish	Unrated
PhishFort	Unrated
Phishing Database	Unrated
Phishtank	Unrated
PREBYTES	Unrated
PrecisionSec	Unrated
Quick Heal	Unrated
Quttera	Unrated
SafeToOpen	Unrated
Sansec eComscan	Unrated
Scantitan	Unrated
SCUMWARE.org	Unrated
Seclookup	Unrated
SecureBrain	Unrated
Snort IP sample list	Unrated
SOCRadar	Unrated
Sophos	Unrated
StopForumSpam	Unrated
Sucuri SiteCheck	Unrated
ThreatHive	Unrated
URLhaus	Unrated
URLQuery	Unrated

Параметр / движок	Значение / вердикт
Viettel Threat Intelligence	Unrated
VIPRE	Unrated
ViriBack	Unrated
VX Vault	Unrated
Webroot	Unrated
Xcitium Verdict Cloud	Unrated
Yandex Safebrowsing	Unrated
ZeroCERT	Unrated
ZeroFox	Unrated
Куда редиректит	нет (без редиректа)
Что выводит (кратко)	Firestore error. Please ensure that you have the URL of your Firestore Realtime Database instance configured correctly.
Где припаркован	нет данных

Как работает клоака

В начале

Снаружи это обычная мобильная аркада/лабиринт: в магазине и на иконке написано «Tigrano Maze Zip Cat», внутри есть Flutter-экран MainActivity с игровым контентом. Но при запуске человек почти никогда не попадает сразу в игру. Сначала открывается «шлюз» GateActivity — тихий экран без кнопок, который решает, куда вести дальше.

Обман такой: модератору Google Play, боту или «неподходящему» пользователю показывают безопасную картинку — либо локальную Privacy Policy, либо саму игру-заглушку. «Нужному» пользователю сервер присылает другую ссылку. Её открывают во встроенном браузере внутри приложения (WebView — окно, которое показывает сайт как будто это часть приложения).

Путь «боевого» пользователя заканчивается на внешнем веб-адресе из ответа startup-API (поле nbu4xl). В самом APK конечный сайт казино/оффера не зашит: адрес приезжает с удалённого сервера. В коде явно есть флаг keitaro_off — намёк на связку с трекером Keitaro (система, которой часто режут трафик на «белый» и «чёрный»).

Кому что показывают

Белая страница / обычный режим. Её видят: модератор стора, бот, пользователь с «блок-токеном», таймаут шлюза или ответом ok + keitaro_off. Что именно видит: либо Lc0Activity с локальной Privacy Policy из файла assets (file:///android_asset/p9/index.html) — нейтральный текст про приватность без офферов; либо Flutter MainActivity — обычная игра «Tigrano Maze Zip Cat», будто приложение именно такое.

Чёрный / боевой режим. Туда попадает пользователь, которому startup-ответ вернул непустой nbu4xl (URL назначения). Открывается S0FrameActivity: полноэкранный WebView с включённым JavaScript и DOM Storage, и в него грузится эта ссылка. Это уже не лабиринт, а веб-лендинг/оффер по адресу с сервера.

Как приложение решает, кого куда пустить

- 1) Firebase Realtime Database (удалённая «записка» с настройками). Что смотрит: узел Rt0 на домене ranoaudio-mix-default-rtdb.europe-west1.firebaseio.com. Условие: за ~5 секунд пришли поля hApi (базовый URL API) и опционально hFp. Результат: адрес API записывается в RuntimeConfig; если hApi пустой — дальше ходить некуда. Запасной адрес по умолчанию — https://ranoaudio-mix.firebaseio.com/.
- 2) Гео / язык / устройство через startup-запрос. Что смотрит клиент отправляет на сервер: locale (язык-страна), country, model телефона, manufacturer, ширину и высоту экрана, installId, idfv, appVersion — на endpoint startup с обфусцированными именами параметров (b8q2la, c5v7nk и т.д.). Условие фильтрации решает сервер (в APK серверной логики нет). Результат: JSON StartupResponseDto с псевдонимными полями.
- 3) Разбор ответа на клиенте (Decision). Что смотрит → условие → результат: непустой nbu4xl → открыть S0/WebView с этим URL; a2c8yo == open_policy → Privacy Policy; непустой v9m2pt → fallback block_token → увести в игру; z3q8rs == ok и l7s5hk == keitaro_off → белая Flutter-игра (MainStub); ok без URL → снова Policy; иначе fallback по e4f7nr → MainActivity.
- 4) Deep link click_id. Что смотрит: query-параметр click_id у http/https Intent (приложение заявлено как BROWSABLE). Условие: параметр есть и не пустой. Результат: кладётся в pending_click_id (DataStore) и

позже уходит POST'ом на сервер — атрибуция клика/оффера.

5) Флаги в локальном хранилище. Что смотрит: `p7_pd` (приняли ли `policy`), `install_id/idfv`, `fcm_token`.
Результат: идентификаторы устройства и согласие уезжают на API (`persist/push`), чтобы сервер узнавал повторные запуски и мог слать уведомления.

Цепочка по шагам

Шаг 1. Пользователь запускает приложение → открывается `GateActivity` (шлюз), а не сразу игра → система начинает тихую проверку.

Шаг 2. `GateActivity` читает `Intent`: если в ссылке есть `click_id` → сохраняет `pending_click_id` → сервер потом свяжет клик с установкой.

Шаг 3. Клиент спрашивает `Firebase RTDB` (узел `Rt0`) → зачем получить актуальный `hApi` → в `RuntimeConfig` появляется `baseUrl API` (или остаётся запасной `ranoaudio-mix.quest`).

Шаг 4. `Retrofit` дергает `GET startup` с данными устройства/страны/языка → сервер (часто связка с `Keitaro`) решает «белый/чёрный» → клиент получает `StartupResponseDto`.

Шаг 5. `Decision` разбирает поля: при наличии `n6u4xl` выбирает `OpenS0` → зачем открыть боевой URL → `uiState = S0(dest=URL)`.

Шаг 6. `GateActivity` стартует `S0FrameActivity`, передаёт URL в `extra x0d` → `WebView` грузит ссылку с JS → пользователь видит лендинг/оффер.

Шаг 7. На `onPageFinished` `WebView` «запоминает» чужой `http(s)`-хост (не `firebase` и не `date123456.com`) через `persist/save_link` → финальный URL уходит на сервер для атрибуции.

Шаг 8. Если сервер сказал `open_policy` или `ok` без URL → `Lc0Activity` показывает локальную `Privacy Policy` → белая витрина для стор.

Шаг 9. Если `ok + keitaro_off`, ошибка, `block_token` или таймаут → `MainActivity` (Flutter-игра) → модератор/отклонённый трафик видит «настоящее» приложение.

Шаг 10. Параллельно FCM-токен пишется в `prefs` и уходит `postPush` → сервер может слать пуши/ретаргет на устройство.

Технические уловки

XOR-шифрование строк (ключ в `AbstractC1473m3`). URL `Firebase`, `https`, `open_policy`, `keitaro_off`, `save_link`, путь к `privacy-asset`, хост `date123456.com` спрятаны за XOR. Зачем: усложнить простой поиск по APK. В итоге при работе расшифровываются рабочие URL и команды решения.

Обфусцированные имена полей API (`z3q8rs`, `n6u4xl`, `a2c8yo`, `l7s5hk`, `query b8q2la...`). Зачем: скрыть смысл «статус / URL назначения / действие / флаг `Keitaro`» от поверхностного анализа.

Динамический `baseUrl` из `RTDB` (`hApi`) плюс запасной `ranoaudio-mix.quest`. Зачем: менять сервер клоаки без обновления APK в `Google Play`. Боевой URL оффера в коде не лежит.

`WebView` без `Custom Tabs`. Боевой контент держат внутри приложения (`S0Frame`); внешние схемы — через `ACTION_VIEW`. Зачем: контроль навигации, перехват `privacy-URL`, `persist` финального хоста.

Локальная белая `Privacy Policy` в `assets/p9`. Не зависит от сети. Зачем: всегда есть «чистая» страница для `open_policy`.

Роль подозрительных доменов

`ranoaudio-mix-default-rtbd.europe-west1.firebaseio.com` — «мозг» конфигурации на шагах 3–4. С него читается `Rt0/hApi` (базовый URL API решения). Сейчас корень отдаёт ошибку `Firebase` (инстанс снаружи не сконфигурирован или закрыт). Это не лендинг оффера, а источник адреса сервера клоаки.

`ranoaudio-mix.quest` — запасной/дефолтный API-хост (XOR-строка в коде). Используется как `baseUrl`, пока `RTDB` не подставит другой `hApi`. На него ходят `startup` / `save_link` / `push_token` / `click`. Это рабочий сервер решения, не финальный лендинг.

`date123456.com` — зашитый «белый» хост `privacy`. Если `WebView` попал на `https://date123456.com` (или на `package/privacypolicy`), приложение открывает `read-only Policy` и не считает страницу боевым оффером для `save_link`. Не «мозг» решения и не финальный оффер.

Финал для пользователя

После всех проверок «нужный» пользователь оказывается на веб-странице по URL из поля `n6u4xl` ответа `startup`. Тип сайта в статическом коде не зафиксирован (казино / беттинг / другой оффер): адрес динамический и приезжает с API, с намёком на `Keitaro` через флаг `keitaro_off`. «Ненужный» видит либо локальную `Privacy Policy`, либо Flutter-игру `Tigrano Maze Zip Cat`. Без живого ответа `hApi+startup` конечный оффер из APK не извлекается.